Transilience

SECURITY ADVISORY

# Trivy Security Scanner GitHub Actions Breached

Analysis of the Trivy security scanner breach, where a malicious release was distributed via compromised GitHub Actions.

REPORT ID
`breach-20260322T001326Z-2b70aade2bb343a69394df986732b422`

CREATED
2026-03-22

THREAT ACTOR
teampcp

CLASSIFICATION
**TLP:WHITE**

# Executive Summary

Compromised Tool

**Trivy Scanner**

Widely used open-source vulnerability scanner

Attack Vector

**GitHub Actions**

Compromised release process

Impact

**Supply Chain**

Malicious binaries distributed via official channels

## Overview

The Trivy security scanner, a widely used open-source vulnerability scanner in DevSecOps pipelines, was compromised on March 19, 2026, for the second time in three weeks. The malicious v0.69.4 release was published via the project's own aqua-bot automation, reached Homebrew, and triggered normal downstream integrations before maintainers caught it. This incident highlights the risk of using trusted tools as attack vectors in supply chain attacks.

### Key Findings

- **Compromised Release Process:** The attacker compromised the release process of Trivy, pushing a malicious release (v0.69.4) through the project's own automation (aqua-bot). This allowed the attacker to distribute a malicious binary through official channels, which is a classic supply chain attack.
- **Persistent Access:** The attacker maintained persistent access to Aqua Security's release automation even after the initial compromise on February 28, 2026. This suggests that the remediation efforts after the first incident were insufficient and allowed for a second, more damaging compromise.
- **Coordinated Cover-Up:** The attacker attempted to cover their tracks by deleting the original incident discussion (#10265) and flooding a replacement discussion with spam bot comments. This indicates a deliberate effort to slow down incident response and prevent affected users from learning about the compromise.
- **Widespread Impact Across CI/CD Ecosystem:** Malicious binaries propagated rapidly through Homebrew, Helm chart version bumps, and GitHub Actions workflows. Mass deletion of GitHub Action tags caused widespread CI breakages for pipelines relying on floating or deleted versions.

# Breach Campaign Overview

## Campaign Details

### Campaign Name

`Trivy Supply Chain Attack`

### Timeline

**Breach Window:** 2026-02-28 - 2026-03-19
**Public Notification:** 2026-03-19

### Primary Targets

- DevSecOps pipelines
- CI/CD environments
- macOS developers
- GitHub Actions workflows

## Healthcare Breach Landscape

Supply chain attacks targeting open-source tooling are an increasing threat to DevSecOps environments. This incident demonstrates the high value of security tools as targets due to the trust and network access they are granted. Compromised tools used as trustworthy gatekeepers can rapidly propagate malware across hundreds or thousands of downstream projects.

### 2024-2025 Statistics

**2**
Total Incidents

**2**
Confirmed Disclosures

### Top Breaches (2024-2025)

- Codecov Supply Chain Attack: (2021)
- XZ Utils Backdoor: Potentially widespread (2024)

# Threat Actor Attribution

## Actor Profile

**Name:** teampcp

**Attribution:** Associated with previous GitHub supply chain attacks. Their signature tactics were visible in both the February hackerbot-claw incident and the March follow-up. Demonstrates high organization and resources.

**Motivation:** potentially malicious code injection and disruption

## Attack Techniques

- Compromised CI/CD pipelines
- Pull request target misconfiguration
- Spam bot flood
- Deletion of incident discussions

## MITRE ATT&CK Tactics

TA0001 - Initial Access | TA0005 - Defense Evasion | TA0006 - Credential Access | TA0040 - Impact

# Technical Analysis & Indicators

## Indicators of Compromise (IOCs)

### Indicators of Compromise (IOCs)

The following IOCs were shared by community researchers and recovered from deleted discussions. Finding any of these signals a confirmed compromise.

#### Behavioral Indicators

- Installation of Trivy v0.69.4
- Unexpected outbound network connections from CI runners/dev machines that ran Trivy on March 19, 2026, to non-Aqua domains
- Falco alerts for unexpected DNS lookups from Trivy process
- Use of setup-trivy GitHub Action without a version pin
- CI build logs showing trivy AND 0.69.4 in job outputs from March 19
- Broken GitHub Actions pipelines pinned to deleted tags v0.2.1-v0.2.5

#### Data Exfiltration Patterns

- C2 beaconing to typosquatted domains (attacker-controlled)
- Outbound connections from scanner processes to domains not in *.github.com, *.aquasec.com, *.ghcr.io

## Malware & Vulnerabilities

#### Malware Analysis

Family: `C2 Phone-Home`

Malicious v0.69.4 binaries contained code that phones home to a typosquatted C2 domain. This allows the attacker to gain control over the compromised system. The payload blended in with legitimate update traffic, highlighting the risks posed by implicit trust in security tool binaries.

#### Attack Progression

1. **Initial Compromise**
   On February 28, 2026, an autonomous bot called hackerbot-claw exploited a pull_request_target workflow misconfiguration in the aquasecurity/trivy repository. The attack stole a Personal Access Token (PAT) from the workflow environment, temporarily privatised the repository, deleted historical releases, and pushed a suspicious artifact to the Open VSX marketplace.

2. **Privilege Escalation**

2 With the stolen PAT, the attacker deleted all GitHub Releases between v0.27.0 and v0.69.1 and gained the ability to manipulate critical project automation. This access paved the way for further supply chain compromise.

3 **Malicious Release**
On March 19, 2026, using persistent access, the attacker published malicious v0.69.4 binaries via the project's own aqua-bot automation. The release binaries contained malware that phones home to a typosquatted C2 domain. Automated downstream systems—including Homebrew, Helm charts, and documentation tools—picked up and distributed the compromised release.

4 **Cover-Up**
The attacker deleted Aqua Security's original February disclosure thread (discussion #10265), removed version tags on the aquasecurity/setup-trivy GitHub Action (breaking pipelines), and executed a spam bot operation to bury incident details, flood the real discussion thread, and slow incident response.

## Compromised Data Categories

### Binaries

- Trivy v0.69.4

### CI/CD Pipelines

- GitHub Actions workflows
- Homebrew installations
- Helm chart version bump automations
- Github Action runners

### Credentials

- GitHub Personal Access Token (PAT)

# Impact Assessment & Compliance

## Sectoral Impact

The compromise of the Trivy security scanner had a significant impact on DevSecOps pipelines and CI/CD environments. Automated dependency update tools, infrastructure-as-code systems, and continuous integration runners that trust open-source releases by default were at immediate risk. Pipelines relying on floating version pins or deleted tags suffered outages. Homebrew and internal chart repositories also propagated the malicious release.

### Impacted Sectors

Software Development — High

DevSecOps — High

### Geographic Distribution

- Global

## Regulatory Compliance

### Applicable Regulations

- SOC 2
- ISO 27001
- NIST Cybersecurity Framework

### Compliance Gaps Identified

- Insufficient workflow configuration in GitHub Actions (missed risk in `pull_request_target` context)
- Incomplete secret rotation after initial compromise
- Lack of binary integrity verification in CI/CD pipelines
- Inadequate monitoring of outbound network connections from CI runners
- Workflows using floating version or tag pins instead of immutable references

# Data not available in the document

Data not available in the document

No incident-specific cost data or external quantification provided in the source material.

### Affected Partners

- Homebrew
- Open VSX marketplace
- Users of aquasecurity/setup-trivy GitHub Action
- Helm Chart and Docs downstream automations
- Organizations integrating Trivy as a security gate in their own CI/CD pipelines

### Dark Web Monitoring

Ongoing dark web monitoring is recommended to identify any leaked credentials or sensitive information related to the Trivy compromise. Monitor for the presence of exposed PATs or references to the Trivy breach in underground forums.

Monitor for mentions of Trivy, Aqua Security, and related infrastructure. Any leaks of secrets from the compromised pipelines—or sale of access—should be investigated for possible follow-on attacks.

# Mitigation Recommendations

## Strategic Recommendations Overview

Immediate actions are required to mitigate the impact of the Trivy compromise and prevent future incidents. These include version audits, updating all affected pipelines, enabling strict workflow hygiene, and verifying integrity of all security tooling.

| 7 | 7 | Immediate |
|---|---|---|
| Critical & High Priority | Immediate Action Required | Implementation Target |

### Check Trivy Version

Critical

Run trivy --version on every machine, CI runner, and container that uses trivy. If any shows 0.69.4, treat that system as compromised and isolate it immediately. Downgrade to 0.69.3 or wait for a verifiable clean release.

**Timeline:** Immediate **Effort:** Low

### Update setup-trivy Action

Critical

Check all GitHub Actions workflow files for aquasecurity/setup-trivy references. Update any that pin to v0.2.1 - v0.2.5 to v0.2.6 to avoid broken jobs and eliminate any exposure to compromised binaries.

**Timeline:** Immediate **Effort:** Low

### Review CI Build Logs

High

Review CI build logs from March 19, 2026—identify any job that installed or ran trivy during the malicious window to determine potential exposure.

**Timeline:** Immediate **Effort:** Medium

### Check for Unexpected Outbound Connections

High

If trivy v0.69.4 ran in your CI pipeline, check for unexpected outbound network connections from those runners to non-Aqua domains. Use firewall, EDR, and DNS logs to corroborate compromise.

**Timeline:** Immediate **Effort:** Medium

### Pin setup-trivy Action to Commit SHA

Critical

Pin the setup-trivy action to a specific commit SHA—not just a tag. Tags can be deleted and recreated; commit SHAs cannot be changed.

**Timeline:** Immediate **Effort:** Low

### Audit pull_request_target Workflows

High

Audit all pull_request_target workflows. Any use of this trigger with secrets, write permissions, or untrusted code must be refactored to remove potential for downstream compromise.

**Timeline:** Within 7 days **Effort:** Medium

### Verify Binary Integrity

Critical

Verify trivy binary integrity with checksum before running in pipelines. Add trivy --version output verification as a pipeline step and cross-reference with trusted release artifacts.

**Timeline:** Within 7 days **Effort:** Medium

## Implementation Roadmap

### Phase 1: Immediate Containment (Days 1-3)

- Check Trivy Version
- Update setup-trivy Action
- Review CI Build Logs
- Check for Unexpected Outbound Connections

### Phase 2: Hardening (Weeks 1-2)

- Pin setup-trivy Action to Commit SHA
- Audit pull_request_target Workflows
- Verify Binary Integrity

## References & Sources

How Trivy Was Compromised to Deliver Malware (Again)

## Report Information

ID breach-20260322T001326Z-2b70aade2bb343a69394df986732b422

Version 1.0

Created 2026-03-22

Modified 2026-03-22

Transilience

Published 2026-03-22